

NARRATIVA EXPLICATIVA

Contexto, Propósito y las Cinco Preguntas Incómodas

Kit de Encuesta CAPEC-ESP · Documento C · Versión 1.0 · Abril 2026

«*Nombrar correctamente las cosas es el principio de toda sabiduría.*»

— Confucio (quien, sin saberlo, anticipó la necesidad de un catálogo de patrones de ataque como CAPEC)

1. POR QUÉ EXISTE ESTA ENCUESTA EN ESTE MOMENTO CONCRETO

Hay estudios que nacen porque alguien tuvo una buena idea en un congreso. Y hay estudios que nacen porque la realidad se ha vuelto tan urgente que la única respuesta intelectualmente honesta es medir, clasificar y publicar. Esta encuesta pertenece inequívocamente al segundo tipo.

España cerró 2025 con **122.223 incidentes de ciberseguridad** registrados por el INCIBE, un incremento del 26% respecto al ejercicio anterior. El país ocupa la cuarta posición entre los objetivos gubernamentales europeos según la Agencia Europea de Ciberseguridad (ENISA). El anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad —la transposición nacional de NIS2— lleva meses en tramitación parlamentaria. El nuevo Centro Nacional de Ciberseguridad fue anunciado en octubre de 2025 con una dotación presupuestaria de 1.157 millones de euros para el periodo 2025–2029. Todo apunta en la misma dirección: el ecosistema tiene recursos, regulación y voluntad política.

Lo que falta, con precisión casi quirúrgica, es saber exactamente dónde estamos.

Y eso —precisamente eso— es lo que esta encuesta viene a medir.

2. QUÉ ES CAPEC Y POR QUÉ IMPORTA

2.1 La metáfora del naturalista

Imagine que los ataques informáticos fueran especies de depredadores en un ecosistema. La biología dispone de dos enfoques para estudiarlos: la respuesta reactiva caso a caso —que equivale a esperar a que el depredador ataque para catalogarlo— o la taxonomía sistemática previa, que identifica los patrones de comportamiento, los hábitats preferidos y los métodos de caza antes de que el ataque se produzca.

CAPEC es la taxonomía sistemática de los depredadores digitales. No cataloga ataques específicos (eso lo hace CVE) ni a los atacantes concretos (eso lo hace ATT&CK). Cataloga los **patrones recurrentes de ataque**: los métodos, las condiciones de susceptibilidad, las rutas de explotación y la severidad típica que los adversarios reproducen una y otra vez, independientemente de quiénes sean o qué objetivo persigan.

En la versión 3.9 —la actual— CAPEC contiene **559 patrones de ataque** organizados en nueve mecanismos de ataque y seis dominios. Cada entrada incluye dos indicadores de primera importancia:

Likelihood_of_Attack (la probabilidad de que un adversario use ese patrón) y Typical_Severity (la severidad típica de su impacto). Son, en esencia, los parámetros probabilidad e impacto que cualquier metodología de gestión de riesgos exige.

2.2 La diferencia entre CAPEC y ATT&CK

Lo que hace a CAPEC especialmente valioso —y lo que lo distingue de MITRE ATT&CK— es que opera en la capa de **diseño y arquitectura**: antes de que el ataque ocurra, no después. ATT&CK describe las tácticas y técnicas que los adversarios *ya están usando*. CAPEC describe los patrones que *pueden usar* cualquier adversario en cualquier entorno.

Dicho de forma más directa: ATT&CK es la cámara de seguridad que captura el robo. CAPEC es el arquitecto que diseñó el edificio para que los ladrones no tuvieran por dónde entrar en primer lugar.

3. EL PAISAJE DE AMENAZAS QUE HACE URGENTE ESTA MEDICIÓN

3.1 La industrialización del ataque mediante IA generativa

2025 ha confirmado lo que los investigadores advertían desde 2023: la inteligencia artificial generativa ha democratizado el ataque sofisticado. Los incidentes de phishing potenciados con IA crecieron un 1.265% en 2024. El vishing —llamadas fraudulentas con voz sintética— aumentó un 442%. Por primera vez en la historia de la ciberseguridad, un adversario sin ninguna competencia técnica puede lanzar un ataque de ingeniería social de calidad profesional contra miles de objetivos simultáneamente y a coste prácticamente nulo.

Los patrones CAPEC más relevantes en este contexto —CAPEC-98 (Phishing), CAPEC-163 (Spear Phishing), CAPEC-195 (Principal Spoof)— datan de cuando estas técnicas requerían pericia manual y tiempo humano. La pregunta que esta encuesta formula, con toda su carga incómoda, es: **¿han actualizado las organizaciones sus controles al ritmo en que la IA ha actualizado las capacidades del adversario?**

3.2 La cadena de suministro como el nuevo perímetro vulnerable

El ataque a SolarWinds en 2020 fue el aviso. XZ Utils en 2024 confirmó que no fue una anomalía sino el inicio de una tendencia estructural. Los ataques a la cadena de suministro de software se han duplicado en 2025. Los patrones CAPEC-437, CAPEC-538 y CAPEC-695 (Repo Jacking) describen con precisión los vectores que los adversarios están explotando en pipelines de integración continua, repositorios de paquetes y actualizaciones de software de terceros.

La ironía —y la ironía es el tono correcto para describir este estado de cosas— es que muchas organizaciones invierten millones en proteger su perímetro interno mientras sus dependencias de software se actualizan automáticamente desde repositorios que nadie ha examinado en los últimos seis meses.

3.3 El reloj cuántico que ya está en marcha

"Harvest Now, Decrypt Later" no es ciencia ficción. Es la denominación técnica de una estrategia que actores de amenaza sofisticados —principalmente estados-nación— ya están ejecutando: capturar

tráfico cifrado hoy para descifrarlo cuando los ordenadores cuánticos alcancen potencia suficiente. El 67% de las organizaciones encuestadas en estudios de 2025 ya ha sufrido compromisos HNDL detectados.

NIST publicó en 2024 los primeros estándares de criptografía post-cuántica (ML-KEM, ML-DSA, SLH-DSA). La migración no es opcional; es cuestión de cuándo. Esta encuesta pregunta con cuánta antelación están actuando las organizaciones españolas —y si la respuesta es "aún no", también esa es una medición valiosa.

4. EL ECOSISTEMA REGULATORIO: OBLIGACIÓN DISFRAZADA DE OPORTUNIDAD

La Directiva NIS2 (2022/2555) exige explícitamente en su artículo 21.2 que las organizaciones adopten medidas de gestión de riesgos que incluyan análisis de amenazas, gestión de incidentes, continuidad del negocio, seguridad de la cadena de suministro y formación. CAPEC es la herramienta conceptual que da contenido técnico concreto a cada uno de estos requisitos.

El Esquema Nacional de Seguridad (ENS, RD 311/2022) lleva años exigiendo análisis de riesgos formales. DORA impone a las entidades financieras pruebas de resiliencia operacional (TLPT) basadas en amenazas reales.

En este contexto, la encuesta no pregunta si las organizaciones cumplen la normativa —eso lo hacen los auditores. Pregunta si la normativa ha sido la palanca para adoptar un pensamiento más estructurado sobre las amenazas. Hay una diferencia sustancial entre cumplir una lista de verificación y comprender el patrón de ataque que justifica cada ítem de esa lista. Esta encuesta mide precisamente esa diferencia.

5. LAS CINCO PREGUNTAS INCÓMODAS

Primera pregunta incómoda: ¿Sabe usted, con nombre y número de entrada CAPEC, cuáles son los cinco patrones de ataque más probables contra su organización en este momento? Si la respuesta requiere más de diez segundos de reflexión, hay trabajo que hacer.

Segunda pregunta incómoda: ¿Están sus planes de continuidad de negocio (BCP) y recuperación ante desastres (DRP) diseñados para sobrevivir a los patrones de ataque de alta severidad que CAPEC identifica para su sector? ¿O están diseñados para el tipo de desastres que ocurrirían hace diez años?

Tercera pregunta incómoda: ¿Cuánto software de terceros corre en sus sistemas productivos en este momento, sin SBOM, sin auditoría, actualizado automáticamente desde repositorios que nadie en su organización ha examinado en los últimos seis meses?

Cuarta pregunta incómoda: Su infraestructura de comunicaciones cifradas, ¿utiliza algoritmos que un ordenador cuántico de potencia suficiente podría romper retroactivamente? Y si la respuesta es sí —que lo es en casi todos los casos— ¿tiene un plan de migración con fecha?

Quinta pregunta incómoda: ¿Puede usted, hoy, demostrar ante su Consejo de Administración que la inversión en ciberseguridad está justificada por un análisis de reducción de riesgo basado en amenazas

documentadas, y no simplemente por la presión regulatoria o el precedente presupuestario del año anterior?

Si alguna de estas preguntas genera incomodidad, esa es precisamente la reacción que indica que el instrumento está bien calibrado.

6. LO QUE ESTA ENCUESTA NO ES

Esta encuesta **no es una auditoría**. No busca exponer vulnerabilidades específicas de organizaciones identificables. No es un mecanismo de cumplimiento regulatorio ni un instrumento de control administrativo.

Esta encuesta **no juzga** a quien responde "no usamos CAPEC" o "nunca he oído hablar de este marco". El desconocimiento es un dato tan valioso como el conocimiento, y probablemente más honesto que muchas respuestas aspiracionales que los instrumentos de evaluación tienden a obtener cuando los respondentes sienten que están siendo observados.

Esta encuesta **no promete soluciones**. Promete diagnóstico. Y en ciberseguridad, como en medicina, un diagnóstico correcto vale más que diez tratamientos aplicados a la enfermedad equivocada.

7. LO QUE SÍ ES ESTA ENCUESTA: EL BIEN PÚBLICO QUE PERSIGUE

El resultado de este estudio será el **primer IGM-CAPEC España**: un índice de referencia nacional que permitirá a cualquier organización comparar su nivel de madurez con el promedio de su sector y tamaño. Estará disponible de forma pública y gratuita para INCIBE, CCN-CNI, ENISA y las asociaciones sectoriales, para informar sus políticas de apoyo a las organizaciones.

Pero más allá de los promedios estadísticos, el estudio busca identificar las **palancas de adopción**: qué condiciones —regulatorias, organizacionales, culturales, de liderazgo— determinan que algunas organizaciones adopten marcos como CAPEC de forma proactiva mientras otras esperan a que ocurra el incidente que justifique la inversión retroactiva.

Porque la ciberseguridad reactiva, en el panorama de amenazas de 2025, no es una estrategia conservadora. Es, simplemente, cara.

8. NOTA SOBRE EL TONO DEL INSTRUMENTO

El lector habrá observado que las preguntas de la encuesta están redactadas con un tono que combina rigor técnico con una dosis medida de ironía literaria. Esto no es accidental.

Las encuestas de ciberseguridad tienden a generar, entre sus respondentes más experimentados, una fatiga reconocible: la sensación de estar contestando una lista de verificación diseñada por alguien que no ha gestionado nunca un incidente real, ni ha tenido que explicar a las tres de la madrugada por qué el sistema productivo lleva cuatro horas caído. Para contrarrestar esta tendencia, el instrumento adopta el tono del colega experto que pregunta con franqueza, reconociendo que hay respuestas incómodas y que la incomodidad es información.

Un CISO que sonríe ante una pregunta bien formulada tiene más probabilidad de responder con precisión que uno que siente que está rellenando un formulario burocrático más de los cincuenta que ya tiene pendientes.

Y en investigación, como en ciberseguridad, la precisión de los datos lo es todo.

9. CÓMO SE USARÁN LOS RESULTADOS

Los resultados se publicarán en forma de:

1. Informe ejecutivo — Disponible de forma pública, con índices por sector y tamaño
2. Paper académico — Sometido a revisión por pares en revista indexada en JCR/Scopus
3. Ficha de benchmarking para organizaciones — Descargable para comparar el resultado propio con el sector
4. Informe de política para el Centro Nacional de Ciberseguridad — Con recomendaciones operativas derivadas de los datos
5. Dataset anonimizado — Disponible en repositorio abierto bajo licencia Creative Commons

Kit de Encuesta CAPEC-ESP · Documento C: Narrativa Explicativa · Versión 1.0 · Abril 2026

Fuentes de contexto: INCIBE Balance Ciberseguridad España 2025 · ENISA Threat Landscape 2025 · MITRE CAPEC v3.9 · NIS2 Directiva 2022/2555 · ENS RD 311/2022 · NIST PQC Standards (FIPS 203/204/205) · NIST AI 100-2e2025